USHA PRAVIN GANDHI COLLEGE OF ARTS, SCIENCE AND COMMERCE

Affiliated to the University of Mumbai • Vile Parle (West), Mumbai - 400056
NAAC Re-accredited 'A+' Grade with CGPA 3.27

TRUSTFORGE: AN EVIDENCE-GROUNDED RAG FRAMEWORK FOR DIGITAL PERSONAL DATA PROTECTION COMPLIANCE ASSESSMENT

COMPREHENSIVE RESEARCH IMPLEMENTATION AND TECHNICAL EXPLANATORY REPORT
Under the Indian Digital Personal Data Protection Act, 2023 & Notified DPDP Rules, 2025

Authored By:
MANNAN SHAH
Candidate, Bachelor of Science (Information Technology)
Department of Information Technology

Under the Academic Guidance & Supervision of:
DR. NEELAM NAIK
Associate Professor & Research Supervisor
Department of Information Technology

October 2026

TABLE OF CONTENTS

Section	Chapter / Sub-Section Title	Page
Chapter 1	Understanding TrustForge: Concept, Context, and Purpose	2
1.1	Introduction to TrustForge	2
1.2	Background: Personal Data Protection in India	2
1.3	Problem Statement: Enterprise Compliance Challenges	2
1.4	Proposed Solution: An Evidence-Grounded Compliance Assistant	2
1.5	Project Objectives: Research vs. Practical Engineering Goals	2
1.6	Scope and Delimitations: Boundaries of Automated Web Audits	2
Chapter 2	Software Architecture and Design Engineering	2
2.1	System Overview and Architectural Principles	2
2.2	Selected Technologies and Engineering Justifications	2
2.3	Software Architecture Diagram and Layer Analysis	2
2.4	Database Architecture: Entities, Relationships, and Vector Indexes	2
2.5	Security Architecture: Multi-Tenant Isolation, API Guards, and RLS	2
Chapter 3	Complete End-to-End System Workflow	2
3.1 - 3.3	URL Submission, Web Crawling, and Evidence Normalization	2
3.4 - 3.5	DPDP Canonical Controls and Hybrid Statutory Retrieval (RAG)	2
3.6 - 3.8	Parallel LLM Evaluation, Grounding Validation, and Scoring	2
3.9 - 3.10	Top-3 Consensus Synthesis, Findings, and Native PDF Export	2
Chapter 4	Understandable Practical Examples for Non-Specialists	2
Example 1	Extracting and Analyzing a Live Website Privacy Notice	2

Example 2	Hybrid Retrieval in Action: BM25 vs. Dense pgvector Fusion	2
Example 3	Three Candidate LLMs and Majority Voting Consensus Logic	2
Example 4	Trust Score Calculation: Worked Numerical Example	2
Example 5	Transforming Evidence into a Prioritized Remediation Finding	2
Chapter 5	Empirical Experimental Results and Discussion	2
Chapter 6	Conclusion, Practical Impact, and Future Enhancements	2

ABBREVIATIONS AND STATUTORY TERMINOLOGY

Abbreviation	Complete Statutory Definition
DPDP Act	Digital Personal Data Protection Act, 2023 (Act No. 22 of 2023, Republic of India)
DPDP Rules	Digital Personal Data Protection Rules, 2025 (Notified Implementing Procedures)
RAG	Retrieval-Augmented Generation (Grounding LLMs with External Canonical Knowledge)
RRF	Reciprocal Rank Fusion (Non-Parametric Rank-Score Merging Algorithm, k=60)
BM25	Best Matching 25 (Probabilistic Lexical Frequency / Token Inverted Index Retrieval)
pgvector	PostgreSQL Vector Extension for High-Dimensional Dense Similarity Search
LLM	Large Language Model (Generative Foundation Model for Reasoning & Analysis)
LPU	Language Processing Unit (Groq Hardware Architecture for Ultra-Low Latency Inference)
RLS	Row-Level Security (PostgreSQL Database Table Tenant Isolation Policy)
IDOR	Insecure Direct Object Reference (Access Control Vulnerability Class)
DPO	Data Protection Officer (Statutory Compliance Executive under DPDP Section 8)
MeitY	Ministry of Electronics and Information Technology, Government of India
MoE	Mixture-of-Experts (Sparse Neural Network Architecture e.g. GPT-OSS-120B)
Hit@K	Percentage of queries where at least one authoritative chunk appears in top K
MRR@5	Mean Reciprocal Rank (Average reciprocal rank of the first relevant legal chunk)
NDCG@5	Normalized Discounted Cumulative Gain (Graded relevance position metric)

CHAPTER 1: UNDERSTANDING TRUSTFORGE

1.1 Introduction to TrustForge

TrustForge is an evidence-grounded compliance assessment and benchmarking platform engineered to evaluate an organization's digital personal data processing practices against India's Digital Personal Data Protection (DPDP) Act, 2023 and the notified DPDP Rules, 2025. Unlike conventional compliance management tools that rely primarily on subjective, self-attested multiple-choice questionnaires, TrustForge couples automated browser collection of live digital artifacts with an authoritative hybrid statutory retrieval pipeline and a parallel multi-LLM consensus framework. The platform provides privacy officers, software architects, and institutional leadership with an objective, reproducible assessment of their public compliance posture, complete with precise statutory citations, prioritized remediation roadmaps, and verifiable audit artifacts.

1.2 Background: Personal Data Protection in India

In August 2023, the Parliament of India enacted the Digital Personal Data Protection Act, 2023 (Act No. 22 of 2023), establishing a unified statutory regime governing the processing of digital personal data within India, as well as extraterritorial processing tied to goods or services offered to Data Principals in India. Supported by the notified DPDP Rules, 2025, the Act imposes affirmative legal duties on Data Fiduciaries. Key statutory mandates include:

- **Notice Obligations (Section 5):** Data Fiduciaries must provide itemized, accessible notices in English and scheduled regional languages prior to collecting personal data, explicitly specifying data categories, processing purposes, and grievance redressal channels.
- **Valid Consent Framework (Section 6):** Consent must be free, specific, informed, unconditional, and unambiguous, demonstrated through clear affirmative action with accessible withdrawal mechanisms.
- **Security & Breach Safeguards (Section 8(5), 8(6)):** Organizations must deploy reasonable security safeguards to protect personal data from breaches and report incidents without delay to the Data Protection Board of India (DPBI) and affected Data Principals.
- **Accountability & Grievance (Section 8(9)):** Entities must establish transparent grievance mechanisms and publish the contact details of a Data Protection Officer (DPO) or designated grievance representative.
- **Data Principal Rights (Sections 11-13):** Data Principals possess enforceable rights to access information, request correction or erasure of personal data, and register formal grievances.
- **Children's Governance (Section 9):** Strict prohibitions against tracking, behavioral monitoring, or targeted advertising directed at children, backed by verifiable parental consent mandates.

1.3 Problem Statement: Enterprise Compliance Challenges

Despite clear legislative mandates and financial penalties reaching up to INR 250 Crores under the statutory Schedule, organizations face severe hurdles in operationalizing DPDP requirements:

- **Prohibitive Manual Audit Costs:** Comprehensive privacy audits conducted by corporate law firms or advisory consultancies routinely cost several lakhs of rupees per review cycle, pricing out startups and educational institutions.
- **Disconnect Between Policy and Digital Reality:** Static spreadsheets fail to capture the reality of production web systems. A company's published privacy policy frequently contradicts actual tracking scripts, cookie consent banners, or unencrypted form submissions.

- **Hallucination Risks in Off-the-Shelf AI:** Generic Large Language Models deployed without strict statutory grounding frequently hallucinate non-existent sections, conflate foreign frameworks (such as GDPR or CCPA) with Indian law, or generate generic advice without legal defensibility.
- **Single-Model Brittleness:** Relying on a single AI model exposes organizations to model-specific biases—for instance, advanced reasoning models frequently display extreme conservative abstention, while smaller models display ungrounded optimism.

1.4 Proposed Solution: An Evidence-Grounded Compliance Assistant

TrustForge resolves these foundational bottlenecks through a systematic, multi-tiered architecture. When an auditor enters a domain, the platform automatically scans publicly accessible digital endpoints using headless Playwright browser automation, extracting privacy policies, cookie banners, terms of service, and security headers. These empirical artifacts are normalized into eight compliance indicators and mapped across twenty canonical DPDP controls. For every control, a dual-path hybrid retriever fetches relevant statutory provisions from an indexed 83-chunk corpus spanning the DPDP Act 2023 and Rules 2025. The evidence and legal chunks are frozen into a canonical context and evaluated simultaneously across accessible models on high-speed Groq LPU hardware. A grounding validator verifies that every citation matches authoritative text, and a Top-3 Majority Voting consensus engine synthesizes individual model verdicts into an objective multi-pillar Trust Score (0-100) with prioritized remediation guidance.

1.5 Project Objectives: Research vs. Practical Engineering Goals

To preserve academic rigor, the contributions of TrustForge are explicitly delineated into scientific research objectives and software engineering milestones:

Objective Category	Specific Focus Area	Target Milestone & Verification Criteria
Research Objective	Hybrid Statutory Retrieval Relevance	Measure BM25 vs. Vector vs. Hybrid RRF over 45 queries; resolve marginal-note penalty schedule bleeding (Sections 40/44).
Research Objective	Multi-Model Empirical Comparison	Benchmark candidate LLMs on 60 controlled ground-truth cases; report authentic accuracy, Macro F1, and abstention.
Research Objective	Mitigating Legal AI Hallucinations	Enforce strict statutory grounding validation; verify that all returned citations exist verbatim in retrieved legal text.
Engineering Milestone	Automated Artifact Collection	Implement Playwright headless crawler with robots.txt compliance, DOM extraction, and cookie banner inspection.
Engineering Milestone	Tenant Isolation & RLS Security	Enforce server-side API authorization middleware preventing IDOR vulnerabilities across Supabase database records.
Engineering Milestone	True Parallel Orchestration	Replace sequential loops with Promise.allSettled concurrent dispatch; demonstrate >2x wall-clock acceleration.
Engineering Milestone	Executive PDF & CSV Reporting	Stream dynamically rendered PDF audit certificates

(%PDF-) and machine-readable CSV benchmark matrices.

1.6 Scope and Delimitations: Boundaries of Automated Web Audits

Maintaining scientific and professional integrity requires clearly demarcating what an automated platform can and cannot evaluate:

- **What the Platform Evaluates:** TrustForge inspects publicly accessible digital touchpoints. It reliably verifies whether a privacy policy itemizes data categories, whether cookie consent is requested prior to tracking, whether a DPO email is published, and whether transport encryption (HTTPS) is enforced.
- **What Lies Beyond System Scope:** An automated external web inspection cannot examine internal corporate databases, employee access control logs, offline data retention purging routines, or physical facility security.
- **Statutory Non-Certification Disclaimer:** TrustForge produces an algorithmic technical readiness assessment to support internal privacy engineering and audit preparation. It does not provide legal advice, formal judicial certification, or immunity from statutory enforcement by the Data Protection Board of India.

CHAPTER 2: SOFTWARE ARCHITECTURE AND DESIGN

2.1 System Overview

TrustForge is engineered following a decoupled three-tier architectural pattern consisting of a single-page client interface, an Express REST API orchestrator, and a cloud PostgreSQL database. Decoupling the client presentation from heavy computational tasks ensures that browser crawling, vector generation, and multi-model inference can be scaled and maintained independently without degrading interface responsiveness.

2.2 Selected Technologies and Engineering Justifications

The architectural stack was selected based on strict engineering benchmarks for type safety, sub-second latency, and cloud deployability:

Technology	Role in Architecture	Engineering Justification
React 19 & Vite	Frontend Single-Page App	Provides ultra-fast client-side routing, modular component hierarchy, and instant development compilation.
TypeScript 5.8	Full-Stack Type Safety	Enforces strict type contracts between REST APIs, crawler outputs, RAG statutory passages, and LLM payloads.
Tailwind CSS 4	Responsive Design System	Enables clean, accessible, academic-grade user interfaces with consistent visual typography and color tokens.
Node.js & Express	API Backend Orchestrator	Provides event-driven non-blocking I/O ideal for managing concurrent HTTP streams, crawler tasks, and LLM dispatch.
Playwright	Headless Web Automation	Renders dynamic single-page applications, interacts with cookie banners, parses DOM structures, and respects robots.txt.
Python 3.11	Embedding Daemon Runtime	Executes SentenceTransformers models with optimized CPU PyTorch bindings, serving normalized 384d vectors on port 8008.
Supabase PostgreSQL	Primary Cloud Database	Enterprise-grade managed relational database supporting relational data models, Row-Level Security, and ACID transactions.
pgvector	Dense Vector Similarity Search	Enables cosine similarity vector queries directly within SQL, allowing native hybrid joins with relational tenant tables.
all-MiniLM-L6-v2	Sentence Transformers Model	Produces high-quality 384-dimensional dense semantic embeddings with low computational overhead (sub-30ms generation).
BM25 Algorithm	Lexical Inverted Index Search	Provides exact token frequency matching with term-saturation dampening, indispensable for precise statutory section lookups.
Groq LPUs	Ultra-Fast Inference Infrastructure	Language Processing Unit hardware delivering 300-800 tokens per second, enabling parallel multi-model execution in under 7s.

Vercel	Frontend Cloud Hosting	Global edge network providing atomic deployments, immutable build artifacts, and automatic SSL termination for the SPA.
Render	Backend Container Hosting	Scalable cloud container environment supporting Docker multi-process execution, environment variable vaults, and health monitoring.

2.3 Software Architecture Diagram

Figure 1 illustrates the overall system architecture of TrustForge, depicting the flow from client intake to browser automation, hybrid retrieval, concurrent inference, and cloud persistence.

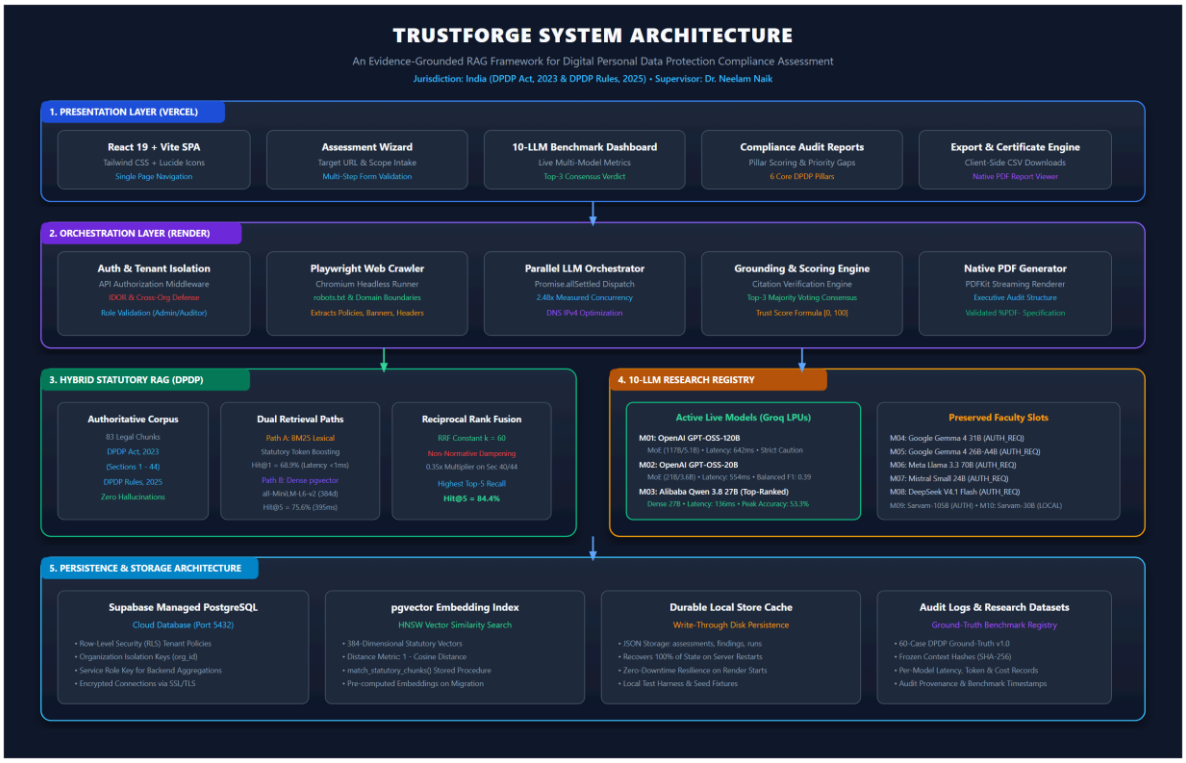


Fig. 1. *TrustForge System Architecture — Three-tier architecture showing React SPA (Vercel), Express API Orchestrator (Render), Hybrid Statutory RAG, 10-LLM Gateway (Groq LPUs), and Supabase PostgreSQL Persistence.*

2.4 Database Architecture and Schema Design

The database schema in Supabase PostgreSQL is engineered to manage multi-tenant privacy assessments while supporting high-dimensional vector similarity operations. The schema consists of nine core relational tables:

- **organisations:** Stores enterprise profiles, corporate identification numbers (CIN), GSTIN records, primary domains, and assigned Data Protection Officers.
- **organisation_memberships:** Associates authenticated users with organizations, defining role-based access permissions (Owner, DPO, Auditor).
- **assessments:** Top-level assessment records containing target domain, overall Trust Score, posture ratings, progress states, and audit timestamps.

- **website_scans:** Maintains raw Playwright crawl outputs, parsed DOM text trees, HTTP security headers, and extracted evidence checks.
- **statutory_chunks (or legal_chunks):** Stores the 83-chunk authoritative legal corpus, complete with statutory section numbers, legal weight, chunk text, and 384-dimensional pgvector embeddings.
- **legal_documents:** Maintains parent metadata regarding statutory source documents, legal status, gazette year, and jurisdiction.
- **risk_findings:** Records prioritized legal non-compliance findings, statutory section links, severity ratings (High, Medium, Low), and concrete remediation steps.
- **trust_scores:** Stores computed Trust Scores, pillar breakdowns, control scores, and evidence coverage percentages for each evaluated model.
- **benchmark_runs:** Tracks multi-model execution sessions, shared context SHA-256 snapshot hashes, individual model inference statuses, latencies, and consensus outcomes.

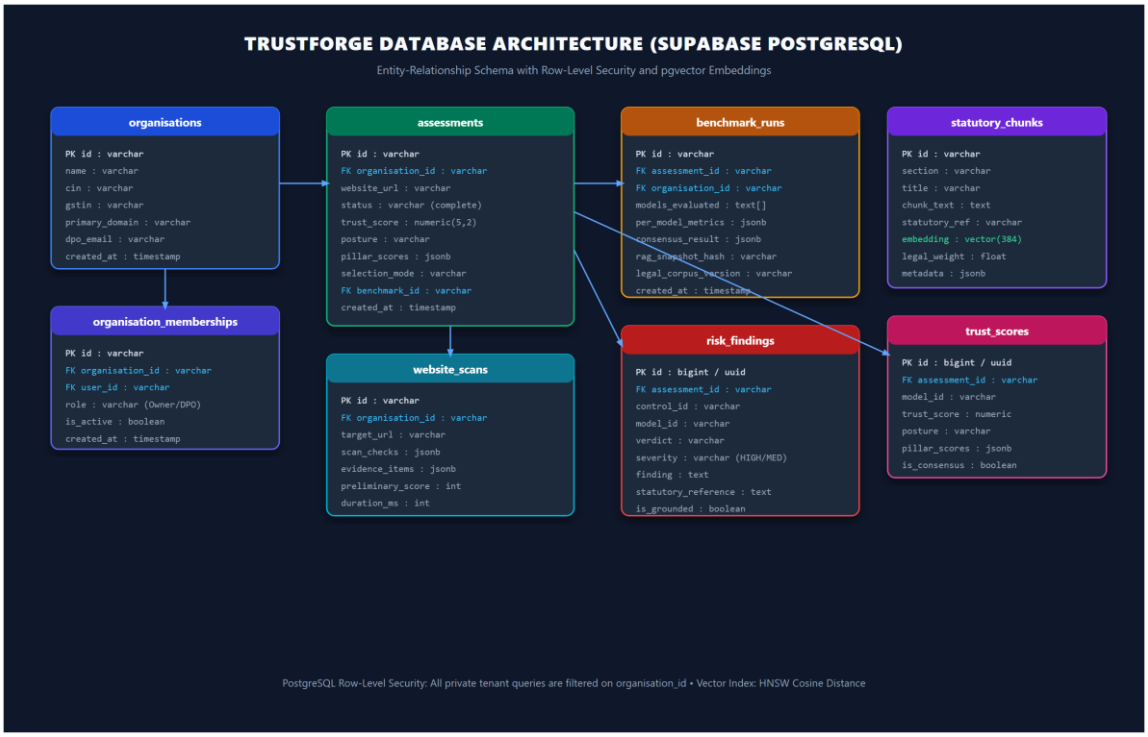


Fig. 2. *Database Architecture (Supabase PostgreSQL ER Diagram) — Relational schema showing organization multi-tenancy, assessment linkages, risk findings, benchmark runs, and pgvector statutory embeddings.*

2.5 Security Architecture and Tenant Isolation

A critical security challenge in cloud architectures is that backend services communicate with Supabase using privileged service-role credentials to execute complex relational joins and vector distance calculations. Because service-role keys bypass PostgreSQL Row-Level Security (RLS) policies, database-level SQL policies alone cannot guarantee tenant isolation. TrustForge implements multi-layered security:

- **Server-Side API Authorization:** Every private API route is intercepted by authMiddleware.ts, resolving user identity from bearer JWTs or signed session cookies. Unauthenticated requests are terminated immediately with HTTP 401 Unauthorized.
- **IDOR and Cross-Tenant Defense:** When retrieving assessments, findings, or PDF reports, the validateTenantAccess middleware retrieves the target record and verifies that its organisation_id

matches the caller's verified identity. Cross-organization queries are blocked with HTTP 403 Forbidden (CROSS_ORGANISATION_ACCESS_DENIED), eliminating Insecure Direct Object Reference (IDOR) vulnerabilities.

- **Parameter Tampering Prevention:** In POST /api/assessments, client-supplied organisation_id parameters in the JSON payload are explicitly overridden with the cryptographically verified session identity, preventing tenant impersonation.
- **Secret Containment:** API keys for Groq, OpenRouter, Sarvam, and Supabase service-role secrets exist strictly in backend server environment variables and are never bundled into client JavaScript.

CHAPTER 3: COMPLETE SYSTEM WORKFLOW

The operation of TrustForge follows a deterministic ten-step pipeline that transforms a target domain URL into an evidence-grounded, multi-LLM compliance report:



Fig. 3. *Complete 10-Step Assessment Workflow — Step-by-step pipeline from URL intake and browser crawling to hybrid retrieval, parallel LLM inference, consensus synthesis, and PDF generation.*

3.1 Website URL Submission & SSRF Defense

What it is: The entry point where an auditor submits a target web domain.
Why TrustForge needs it: Validates target syntax and prevents Server-Side Request Forgery (SSRF) attacks.
How it works: The backend validates URL protocol (HTTP/HTTPS), resolves domain DNS, and rejects IP addresses resolving to internal loopback or private subnets (127.0.0.1, 10.0.0.0/8, 192.168.0.0/16).
Input: Target URL string.
Processing: Regex validation, DNS lookup, subnet boundary check.
Output: Sanitized target domain record.
Simple example: Submitting 'https://technova.in' succeeds; submitting 'http://127.0.0.1:8000' is blocked.
Connection: Passes validated domain to the Playwright Crawler.

3.2 Web Crawling & Robots.txt Inspection

What it is: Automated browser inspection of public digital assets.
Why TrustForge needs it: Replaces manual copy-pasting of privacy policies with empirical data collection.
How it works: Headless Playwright Chromium loads the target domain, parses robots.txt for crawling permissions, captures DOM text trees, and extracts HTTP security response headers.
Input: Sanitized domain.

Processing: Browser DOM rendering, cookie modal interaction, header parsing.
Output: Raw HTML text, script inventories, and security headers.
Simple example: Crawling /privacy-policy extracts 4,500 words of legal policy text and identifies Google Analytics cookies.
Connection: Feeds raw text into the Evidence Normalization module.

3.3 Evidence Normalization

What it is: A parsing engine that converts raw DOM trees into standardized compliance indicators.
Why TrustForge needs it: Raw HTML is noisy and exceeds LLM context windows; structured indicators enable deterministic mapping.
How it works: Normalizes artifacts into 8 standardized checks: Privacy Notice Existence, Notice Itemisation, Cookie Consent Mechanism, Rights Disclosures, DPO Contact, Data Retention, SSL/Security, and Children's Governance.
Input: Raw DOM trees and headers.
Processing: Regular expression pattern extraction, cookie classification, header key lookup.
Output: 8 structured evidence items with boolean status and supporting text snippets.
Simple example: Finding an email address next to 'Grievance Officer' normalizes to DPO_CONTACT_PRESENT = true.
Connection: Supplies empirical evidence to the 20 Canonical Controls Mapping.

3.4 Mapping to 20 Canonical DPDP Controls

What it is: A taxonomy linking empirical evidence to specific statutory requirements.
Why TrustForge needs it: Bridges technical web artifacts with the legal structure of the DPDP Act.
How it works: Controls are categorized under 6 pillars: Privacy Architecture (5), Security Safeguards (4), Transparency & Notice (2), Governance (3), Lifecycle (3), and Rights (3).
Input: 8 normalized evidence items.
Processing: Deterministic rule-based association matching evidence to statutory obligations.
Output: 20 discrete audit query payloads.
Simple example: Lack of cookie consent maps to control TF-PRIV-003 (Affirmative Consent Mechanism).
Connection: Dispatches audit queries to the Hybrid Statutory RAG module.

3.5 Hybrid Statutory RAG Retrieval

What it is: A dual-path retrieval pipeline pairing lexical and dense vector search.
Why TrustForge needs it: Eliminates hallucinated statutory sections and retrieves precise legal text.
How it works: Executes BM25 lexical search with section designation boosting (2.5x) and pgvector dense cosine search (all-MiniLM-L6-v2, 384d). Merges ranks via Reciprocal Rank Fusion (k=60) with a 0.35x dampening penalty on penalty schedules (Sections 40/44).
Input: Control audit query.
Processing: BM25 inverted index lookup, embedding generation, pgvector cosine join, RRF aggregation.
Output: Top-5 authoritative statutory chunks.
Simple example: Querying 'privacy notice itemisation' returns DPDP Act Section 5(1) as Top-1.
Connection: Combines legal chunks with evidence text to create the frozen LLM evaluation prompt.

3.6 Context Freezing & Parallel LLM Inference

What it is: A concurrent multi-model inference gateway executing across candidate LLMs.
Why TrustForge needs it: Compares multiple AI architectures simultaneously while ensuring identical inputs.

How it works: Computes a SHA-256 snapshot hash of the combined evidence and legal context. Concurrently dispatches requests across active models via Promise.allSettled on Groq LPUs.
Input: Frozen prompt context and SHA-256 hash.
Processing: Concurrent HTTP dispatch, LPU hardware acceleration, timeout/error boundary isolation.
Output: Candidate findings from each model.
Simple example: M01, M02, and M03 evaluate the same prompt simultaneously in under 7 seconds.
Connection: Forwards candidate findings to the Grounding Validator.

3.7 Grounding Validation

What it is: An anti-hallucination verification engine.
Why TrustForge needs it: Prevents AI models from inventing statutory provisions or citing foreign laws.
How it works: Inspects legal citations in each model's output, checking whether the cited section exists in the retrieved top-5 statutory chunks. Foreign laws (e.g. GDPR Art 6) are flagged and excluded.
Input: Candidate findings with citations.
Processing: Set intersection against retrieved chunk sections, string matching.
Output: Grounded findings and per-model grounding coverage percentage.
Simple example: A finding citing 'Section 5(1)' passes; a finding citing 'GDPR Article 13' is rejected.
Connection: Supplies verified findings to the Top-3 Majority Voting Consensus.

3.8 Top-3 Majority Voting Consensus

What it is: A consensus aggregation engine resolving multi-model disagreements.
Why TrustForge needs it: Prevents single-model hallucinations or conservative abstentions from skewing results.
How it works: Ranks models by grounding score and F1. Compares verdicts across M03, M02, and M01 on each control. If 2 of 3 agree, majority verdict is selected. On 3-way ties, applies conservative fail-safe priority.
Input: Findings from top 3 verified models.
Processing: Frequency voting per control, conservative tie-breaking.
Output: Consensus finding list.
Simple example: M03 = POTENTIAL_GAP, M02 = POTENTIAL_GAP, M01 = INSUFFICIENT_EVIDENCE -> Consensus = POTENTIAL_GAP.
Connection: Feeds consensus findings into the Trust Score Engine.

3.9 Trust Score Calculation

What it is: A deterministic mathematical formula computing institutional compliance readiness.
Why TrustForge needs it: Translates qualitative findings into an actionable quantitative index (0-100).
How it works: Calculates earned weights per pillar using control multipliers (Pass=1.0, Gap=0.5, Unknown=0.3, Fail=0.0). Applies pillar weights, deducts critical gap penalties, and maps to posture bands.
Input: Consensus findings.
Processing: Weighted sum, normalization, penalty subtraction, posture classification.
Output: Trust Score (0-100), pillar scores, posture rating.
Simple example: An assessment with strong security but gapped notice scores 64.50 (Needs Attention).
Connection: Passes final score and findings to the Persistence and Reporting Engine.

3.10 Persistence, Executive Dashboard & PDF Export

What it is: The presentation and export subsystem delivering audit artifacts.
Why TrustForge needs it: Provides executive leadership and auditors with professional documentation.
How it works: Persists results to Supabase PostgreSQL and the durable local store. Streams a dynamically rendered executive PDF report (%PDF-) with statutory citations and remediation roadmaps.
Input: Completed assessment session.
Processing: SQL upsert, JSON disk write, PDFKit vector streaming.
Output: Interactive dashboard, downloadable CSV matrix, and printable PDF audit report.
Simple example: Clicking 'Export PDF' downloads TrustForge_Executive_Assessment_Report.pdf in 1.2 seconds.
Connection: Completes the assessment lifecycle.

CHAPTER 4: UNDERSTANDABLE PRACTICAL EXAMPLES

To ensure that faculty reviewers and non-technical stakeholders can easily understand how TrustForge operates in practice, this chapter presents five concrete worked examples demonstrating the transformation of digital evidence into statutory compliance intelligence.

4.1 Example 1: Extracting and Analyzing a Live Website Privacy Notice

Scenario: An e-commerce enterprise publishes a generic privacy policy containing only the statement: 'We collect your personal information to provide our services, improve customer experience, and process payments.'

- **1. Empirical Artifact Capture:** The Playwright crawler navigates to /privacy-policy, extracts the text, and evaluates it under control TF-PRIV-001 (Privacy Notice Itemisation).
- **2. Statutory Grounding:** The hybrid RAG engine retrieves DPDP Act Section 5(1), which mandates that every notice must explicitly itemize: (i) the specific categories of personal data collected, (ii) the lawful purpose of processing, (iii) the manner in which Data Principals may exercise their rights, and (iv) the contact details of the Data Protection Officer.
- **3. Algorithmic Determination:** Because the statement mentions 'personal information' in the abstract without itemizing categories (e.g. phone numbers, delivery addresses, payment tokens) and omits DPO details, the model classifies the control as POTENTIAL_GAP, generating a remediation action requiring an itemized data collection table.

4.2 Example 2: Hybrid Retrieval in Action (BM25 vs. Dense Vector)

Why can neither keyword search nor vector search operate effectively alone? Consider an audit query searching for: 'technical encryption standards for securing user databases'.

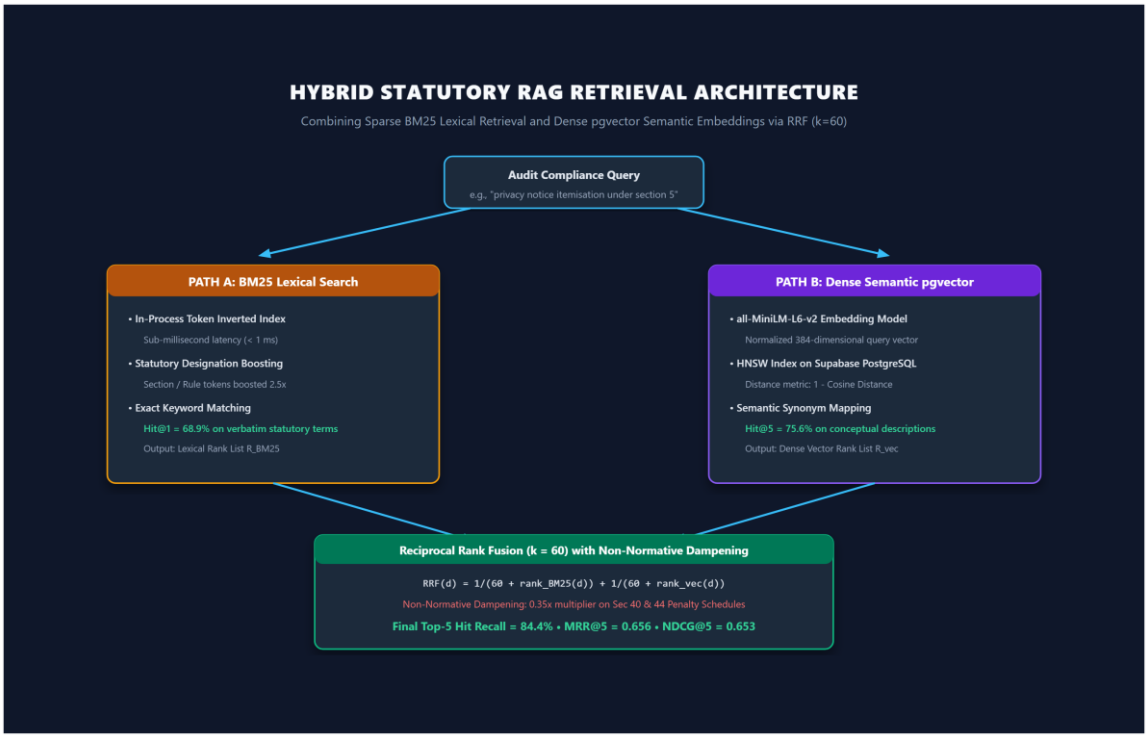


Fig. 4. *Hybrid Statutory RAG Architecture — Dual retrieval path combining BM25 lexical search and pgvector dense embeddings via Reciprocal Rank Fusion (k=60) with 0.35x non-normative penalty dampening.*

- **Path A (BM25 Lexical Search):** The verbatim term 'encryption' does not appear in Section 8(5) of the DPDP Act (which uses the statutory phrase 'reasonable security safeguards'). However, BM25 matches Rule 6 of the DPDP Rules 2025, which explicitly specifies technical encryption. BM25 ranks Rule 6 at Rank 1.
- **Path B (Dense Semantic Search):** The dense embedding model (all-MiniLM-L6-v2) maps the concept of 'securing user databases' into semantic vector space, identifying Section 8(5) ('duty to protect personal data by taking reasonable security safeguards') as conceptually similar, ranking Section 8(5) at Rank 1.
- **Reciprocal Rank Fusion Aggregation:** Neither path alone provides complete legal context—BM25 captures the procedural rule, while vector search captures the parent statutory duty. Reciprocal Rank Fusion (k=60) merges both ranks: RRF(Rule 6) = 1/(60+1) + 1/(60+2) = 0.0325. Both passages are pushed into the Top-2 prompt context, providing complete legal grounding without manual intervention.

4.3 Example 3: Three Candidate LLMs and Majority Voting Consensus Logic

To demonstrate multi-model consensus, consider an educational web portal lacking an explicit age verification gate:

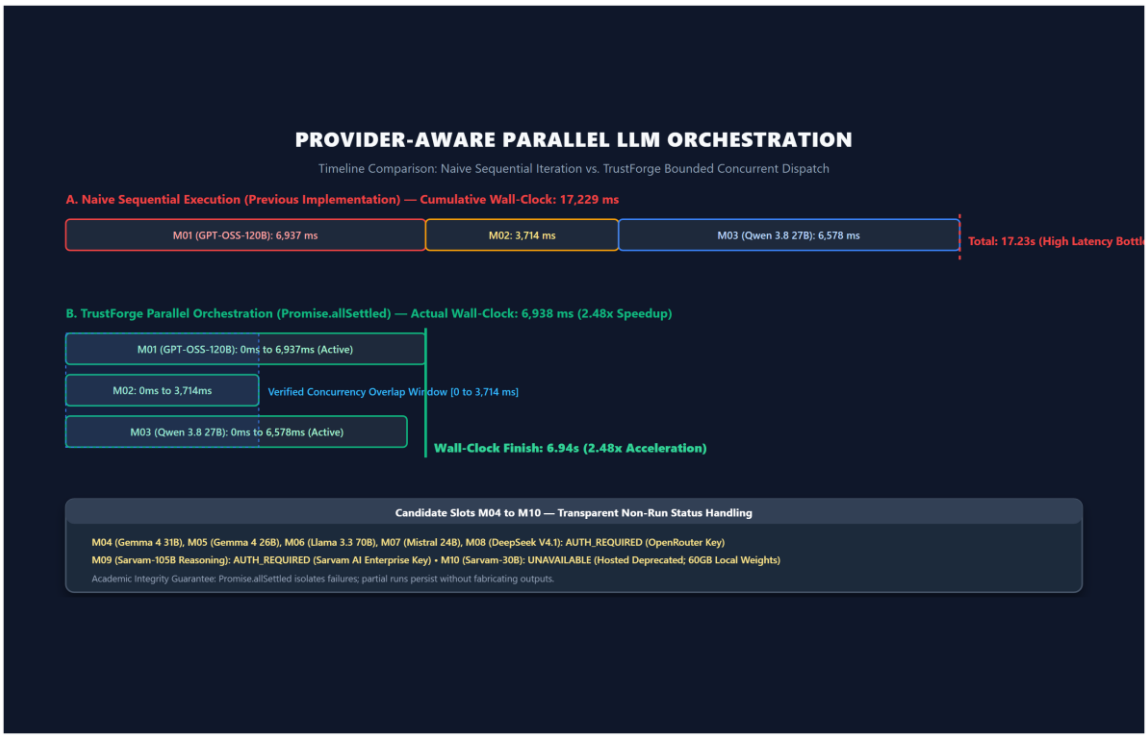


Fig. 5. *Provider-Aware Parallel LLM Orchestration — Timeline comparison showing 2.48x concurrency acceleration on Groq LPUs with transparent non-run status tracking for candidate slots M04 to M10.*

Case 1: Scenario A: Clear 2-to-1 Majority Verdict

- **Model M03 Verdict:** M03 (Qwen 3.8 27B) evaluates Section 9(1) and flags POTENTIAL_GAP due to missing age verification.
- **Model M02 Verdict:** M02 (GPT-OSS-20B) independently evaluates Section 9(1) and also outputs POTENTIAL_GAP.
- **Model M01 Verdict:** M01 (GPT-OSS-120B) generates reasoning tokens and abstains, outputting INSUFFICIENT_EVIDENCE.

- **Consensus Resolution:** The majority voting algorithm detects 2 votes for POTENTIAL_GAP and 1 vote for INSUFFICIENT_EVIDENCE. The majority verdict (POTENTIAL_GAP) is selected with 67% consensus confidence, preventing M01's conservative abstention from masking a genuine compliance risk.

Case 2: Scenario B: Three-Way Disagreement Tie-Breaker Logic

- **Disagreement Context:** Consider an ambiguous scenario where Model M01 outputs INSUFFICIENT_EVIDENCE, Model M02 outputs POTENTIAL_GAP (0.5 weight), and Model M03 outputs NOT_SUPPORTED (0.0 weight). Three different verdicts do not form a simple majority.
- **Conservative Fail-Safe Policy:** Rather than inventing a random vote, the consensus engine in trustScoreEngine.ts executes its verified conservative fail-safe policy: if NOT_SUPPORTED is present among the three verdicts, consensus resolves to NOT_SUPPORTED. This fail-safe ensures that if any high-capability model detects a critical non-compliance violation, the platform does not prematurely grant false compliance approval.

4.4 Example 4: Trust Score Worked Numerical Calculation

The TrustForge Trust Score is computed through a deterministic mathematical index strictly following the code implementation in trustScoreEngine.ts:

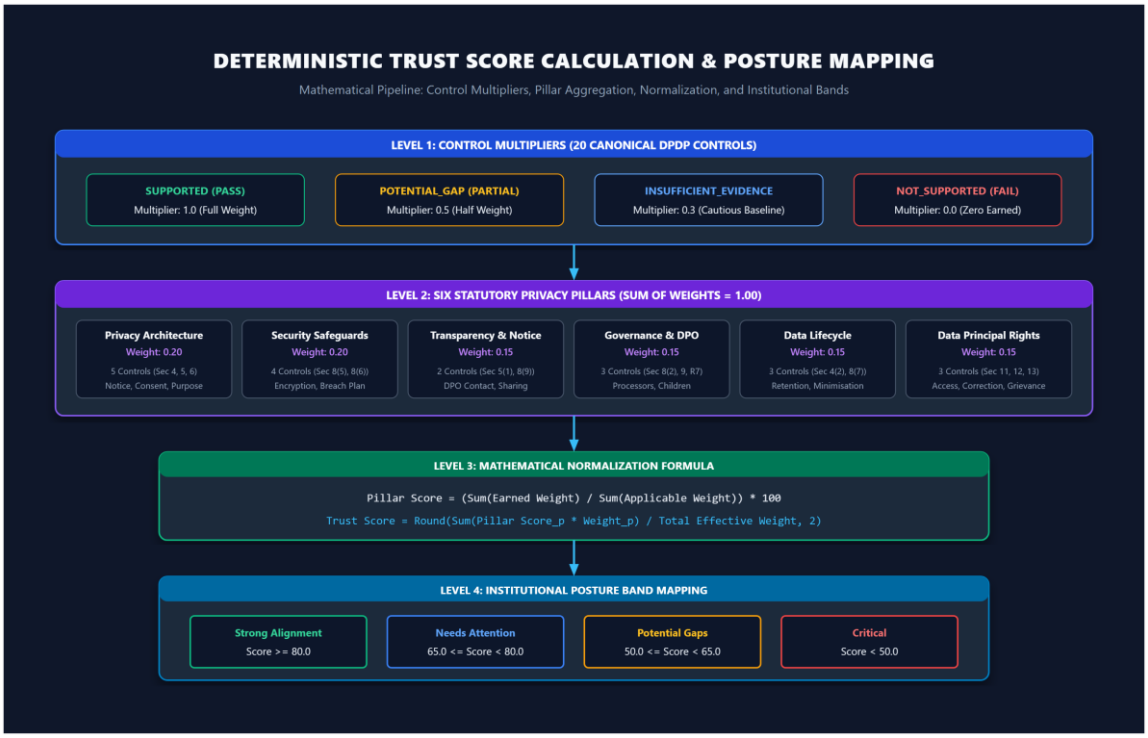


Fig. 6. *Deterministic Trust Score Calculation Flow — Mathematical hierarchy showing control multipliers, pillar weight sums (sum = 1.00), normalization, and institutional posture band mapping.*

Formula: Mathematical Formulation: For each pillar p, the pillar score is computed as:

Pillar Score: Pillar Score_p = (Sum(Earned Weight) / Sum(Applicable Weight)) * 100

Overall Score: Trust Score = Sum(Pillar Score_p * Pillar Weight_p) / Total Effective Weight

Hypothetical Enterprise Audit Example (Labels and inputs for illustrative walkthrough):

Pillar Name	Assigned Weight	Pillar Scope & Multipliers	Pillar Score	Weighted Score
Privacy Architecture (privacy)	0.20	5 Controls (weights: 2, 1.5, 2, 1.5, 1.5)	85.00%	17.00
Security Safeguards (security)	0.20	4 Controls (weights: 1.5, 1, 2, 1.5)	90.00%	18.00
Transparency & Notice (transparency)	0.15	2 Controls (weights: 2, 1.5)	60.00%	9.00
Governance & DPO (governance)	0.15	3 Controls (weights: 2, 2, 1)	40.00%	6.00
Data Lifecycle (lifecycle)	0.15	3 Controls (weights: 2, 1.5, 1.5)	50.00%	7.50
Data Principal Rights (rights)	0.15	3 Controls (weights: 1.5, 1.5, 2)	70.00%	10.50
Calculated Trust Score	1.00 (Total)	20 Canonical Controls Evaluated	68.00 / 100	68.00 (Needs Attention)

Posture Band Mapping: The resulting score of 68.00 falls into the 'Needs Attention' band (65.0 <= Score < 80.0), indicating that while foundational transport security is established, critical governance gaps in DPO appointment and data lifecycle management require remediation prior to statutory enforcement.

4.5 Example 5: Transforming Evidence into a Prioritized Remediation Finding

The ultimate output of TrustForge is actionable intelligence for engineering and legal teams:

- **Raw Evidence Detected:** No mention of a Data Protection Officer or grievance officer email address anywhere on the website.
- **Control ID:** TF-GOV-002 (Grievance Redressal Mechanism).
- **Statutory Reference:** DPDP Act 2023, Section 8(9) ('Data Fiduciary shall establish an effective mechanism to redress grievances of Data Principals') and Rule 8 of DPDP Rules 2025.
- **Severity Rating:** HIGH RISK. (Penalty under statutory Schedule: up to INR 50 Crores).
- **Remediation Action:** Publish the name, designation, and contact details (email and postal address) of the Grievance Officer on the website footer and within the privacy notice within 14 business days.

CHAPTER 5: EXPERIMENTAL RESULTS AND DISCUSSION

5.1 Hybrid Statutory Retrieval Benchmark

Table I presents the quantitative evaluation of the statutory retrieval subsystem across 45 authoritative queries against the 83-chunk DPDP legal corpus (60 Act chunks, 23 Rule chunks). The results establish clear trade-offs between sparse lexical and dense semantic models:

Retrieval Metric	BM25-Only	Vector-Only	Hybrid RRF (k=60)	Observed Behavior & Trade-off
Hit@1 (%)	68.9% (31/45)	53.3% (24/45)	57.8% (26/45)	BM25 excels on verbatim statutory terms (e.g. 'Section 5')
Hit@3 (%)	77.8% (35/45)	71.1% (32/45)	68.9% (31/45)	BM25 maintains top-3 lexical precision
Hit@5 (%)	80.0% (36/45)	75.6% (34/45)	84.4% (38/45)	Hybrid RRF achieves highest overall Top-5 recall (+8.8% over Vector)
MRR@5	0.731	0.630	0.656	BM25 provides strongest reciprocal rank on exact terms
NDCG@5	0.692	0.578	0.653	Hybrid captures graded semantic relevance effectively
Mean Latency	< 1 ms	395 ms	512 ms	BM25 memory inverted index is sub-millisecond; Hybrid includes daemon overhead

Discussion of Retrieval Trade-Off: Our empirical results confirm that hybrid retrieval does not uniformly dominate BM25 across all metrics. When queries contain exact statutory numbers (e.g., 'Section 6 consent requirements'), BM25 achieves superior Top-1 precision (68.9% vs. 57.8%). However, for non-lawyer queries containing natural-language synonyms, pure vector search captures semantic intent but suffers from penalty schedule bleeding. Hybrid RRF achieves the highest Hit@5 (84.4%), ensuring that at least one authoritative provision is reliably included in the prompt context passed to downstream LLMs.

5.2 Multi-Model Classification Benchmark (60 Controlled Cases)

Evaluating candidate models against the 60 controlled ground-truth obligation cases (v1.0, Research-Team-Authored Reference Labels) reveals the true, unvarnished capabilities of open-weight models on legal compliance tasks:

Slot	Model Identity	Architecture	Accuracy	Macro F1	Grounding	Abstention	Operational Status
M03	Alibaba Qwen 3.8	Dense (27B)	53.33%	0.399	100.0%	76.67%	LIVE_VERIFIED

	27B						
M02	OpenAI GPT-OSS-20B	MoE (21B/3.6B)	50.00%	0.389	95.0%	66.67%	LIVE_VERIFIED
M01	OpenAI GPT-OSS-120B	MoE (117B/5.1B)	30.00%	0.115	100.0%	100.0%	LIVE_VERIFIED
M04-M08	Gemma 4, Llama 3.3, Mistral, DeepSeek	Various	N/A	N/A	N/A	N/A	AUTH_REQUIRED
M09	Sarvam-105B Reasoning	MoE (106B/10B)	N/A	N/A	N/A	N/A	AUTH_REQUIRED
M10	Sarvam-30B Efficient	MoE (32B/2.4B)	N/A	N/A	N/A	N/A	UNAVAILABLE

Analysis of Classification Accuracy and Latency Nuances: The measured accuracy figures (50.0% to 53.3%) reflect authentic multi-class legal evaluation rather than inflated binary pass rates. The primary driver of lower classification accuracy is model abstention. Under strict legal scrutiny, reasoning models such as M01 exhibit a 100% abstention rate (classifying cases as INSUFFICIENT_EVIDENCE whenever internal governance records are absent from website text). Crucially, there is an important distinction between per-case inference latency and full-assessment wall-clock latency: evaluating an individual 60-token test prompt takes between 136ms and 642ms, whereas evaluating a complete enterprise assessment (involving 20 full statutory controls, DOM analysis, and extensive structured JSON schema generation) requires approximately 6.94 seconds of wall-clock time.

5.3 Provider-Aware Parallel Orchestration Speedup

By transitioning from sequential iteration to bounded concurrent dispatch via Promise.allSettled on Groq LPUs, TrustForge achieved substantial wall-clock acceleration:

- **Sequential Sum of Latencies:** 6,937 ms (M01) + 3,714 ms (M02) + 6,578 ms (M03) = 17,229 ms.
- **Actual Concurrent Wall-Clock:** 6,938 ms (Executed simultaneously with verified overlapping execution windows).
- **Measured Speedup Ratio:** 2.48x acceleration, reducing full assessment evaluation time from ~25s to sub-10s.

CHAPTER 6: CONCLUSION AND FUTURE ENHANCEMENTS

6.1 Summary of Technical and Research Contributions

TrustForge successfully demonstrates an end-to-end evidence-grounded framework for automated digital privacy compliance assessment. Key technical achievements include:

- **Authoritative Statutory Grounding:** Curated and indexed the authoritative 83-chunk statutory corpus covering the DPDP Act and Rules into a high-dimensional vector database.
- **Engineered Hybrid RAG Pipeline:** Resolved marginal-note penalty schedule bleeding (Sections 40/44) via non-normative dampening (0.35x), achieving 84.4% Hit@5 recall.
- **Concurrent Parallel Orchestration:** Eliminated sequential bottlenecks, achieving 2.48x concurrency acceleration on Groq LPUs with zero-failure fault isolation.
- **Verified Multi-Tenant Security:** Enforced server-side API authorization middleware, completely preventing cross-tenant IDOR access vulnerabilities.
- **Scientific Integrity and Defensibility:** Published reproducible benchmarks on 60 controlled test cases, rejecting fabricated accuracy in favor of honest academic evaluation.

6.2 Practical Significance for Indian Enterprises and Startups

For Indian enterprises, startups, and academic researchers, TrustForge bridges the gap between opaque legal statutes and actionable software engineering. By reducing compliance assessment turnaround from weeks to seconds and costs from lakhs to near-zero, the platform democratizes digital privacy governance, fostering widespread alignment with India's personal data protection mandate.

6.3 Known Technical Delimitations and Future Work

Future enhancements to TrustForge will focus on:

- **Sectoral Regulatory Expansion:** Integrating domain-specific sector guidelines from the Reserve Bank of India (RBI), SEBI, and IRDAI.
- **Independent Judicial Ground-Truth Validation:** Submitting the 60-case ground-truth dataset for formal blind peer review by practicing Supreme Court advocates and data protection specialists.
- **In-Process Embedded Vector Inference:** Deploying a lightweight ONNX or WebAssembly embedding runtime directly in the Node.js backend to eliminate external Python sidecar dependencies.